



PUSAT PENDIDIKAN DAN PELATIHAN
BADAN PUSAT STATISTIK

MODUL PELATIHAN FUNGSIONAL PRANATA KOMPUTER TINGKAT AHLI

AUDIT TI

PUSDIKLAT BPS
2022

Hak Cipta © pada:

Pusat Pendidikan dan Pelatihan Badan Pusat Statistik
Edisi Tahun 2022

**Pusat Pendidikan dan Pelatihan Badan Pusat Statistik
Jl. Raya Jagakarsa NO. 70 Jakarta Selatan 12620**

AUDIT TEKNOLOGI INFORMASI

Modul Pelatihan Fungsional Pranata Komputer Tingkat Ahli

TIM PENGARAH SUBSTANSI:

1. Dr. Eni Lestariningsih, S.Si, MA
2. Dr. Pudji Ismartini M.App.Stat
3. Atas Parlindungan Lubis S.Si, M.Si

PENULIS MODUL:

1. Khairiyah Rizkiyah, SST., M.T.I.
2. Bagus Anda Suhada, SST., M.T.

EDITOR: Bagus Anda Suhada, SST., M.T

COVER: Else Huslijah S.Tr.Stat.

JAKARTA – PUSDIKLAT BPS – 2022

ISBN: -

KATA PENGANTAR



Puji syukur kehadirat Allah SWT yang telah memberikan petunjuk sehingga Modul 5 Audit Teknologi Informasi (TI) ini dapat disusun. Modul ini menguraikan kebutuhan bagi peserta untuk mengelola dan memeriksa sistem TI secara berkala dan efektif guna memenuhi tujuan dan sasaran bisnis. Di samping itu juga diberikan pengenalan mengenai prinsip, pengetahuan, dan keahlian tentang cara mengontrol dan menilai sistem TI yang dibutuhkan oleh seorang pejabat fungsional Pranata Komputer jenjang Keahlian dalam melakukan praktik Audit TI, mencakup: masalah-masalah Audit TI, simulasi, kasus-kasus praktis, dan peluang penugasan penelitian untuk mengembangkan keahlian Audit TI.

Modul ini merupakan salah satu dari tiga belas modul yang diberikan kepada peserta Pelatihan Fungsional Pranata Komputer (Prakom). Ketigabelas modul adalah:

1. Modul 1: Information Technology Enterprise
2. Modul 2: Manajemen Layanan Teknologi Informasi
3. Modul 3: Pengelolaan Data
4. Modul 4: Manajemen Risiko Teknologi Informasi
5. Modul 5: Audit Teknologi Informasi
6. Modul 6: Sistem Jaringan Komputer
7. Modul 7: Manajemen Infrastruktur Teknologi Informasi
8. Modul 8: Sistem Informasi
9. Modul 9: Pengolahan Data
10. Modul 10: Area Teknologi Informasi Spesial
11. Modul 11: Dokumentasi dan Laporan
12. Modul 12: Pengembangan Profesi Pranata Komputer
13. Modul 13: Administrasi dan Penilaian Pranata Komputer

Ucapan terima kasih dan apresiasi kami sampaikan kepada seluruh pihak yang telah membantu dan memberikan masukan dalam penyusunan modul ini. Tanggapan dan saran yang konstruktif kami harapkan guna perbaikan dan pengembangan di masa mendatang. Semoga modul ini dapat bermanfaat bagi pengembangan kompetensi bidang prakom para peserta pelatihan.

Jakarta, Februari 2022
Kepala Pusdiklat BPS

Eni Lestariningsih, S.Si, M.A.
NIP. 197003101994012001

DAFTAR ISI

KATA PENGANTAR.....	i
DAFTAR ISI	ii
DAFTAR GAMBAR.....	v
BAB I PENDAHULUAN	1
1.1. Latar Belakang.....	1
1.2. Deskripsi Singkat.....	1
1.3. Hasil Belajar	2
1.4. Indikator Hasil Belajar	2
1.5. Materi Pokok.....	2
BAB II PENGENALAN AUDIT TI	3
2.1. Konsep dan Definisi Audit TI	3
2.2. Manfaat Audit TI.....	3
a. Manfaat Audit TI pada fase <i>Pre Implementation</i> :.....	4
b. Manfaat Audit TI pada fase <i>Post Implementation</i> :	4
2.3. Tugas dan Peran Auditor TI	4
2.4. Rangkuman.....	5
2.5. Soal Latihan	6
BAB III KERANGKA KERJA AUDIT TI.....	8
3.1. Standar dan Framework Audit TI	8
COBIT	8
ITIL.....	9
CMMI.....	9
PMBOK	10
PRINCE2.....	10
ISO/IEC 20000.....	11
ISO 21500	11
ISO/IEC 38500.....	12
TOGAF.....	12
ISO/IEC 27001.....	13

3.2.	COBIT 5: Salah Satu Best Practice.....	13
3.3.	Standar dan Tata Cara Audit SPBE	17
3.4.	Rangkuman.....	22
3.5.	Soal Latihan	23
BAB IV	ALUR PROSES KEGIATAN AUDIT TI.....	25
4.1.	Menentukan Ruang Lingkup, Kriteria dan Tujuan Audit TI	25
a.	Mengidentifikasi kriteria Audit TI	25
b.	Mengidentifikasi tujuan Audit TI yang relevan	25
c.	Menentukan spesifikasi sistem dan unit/fungsi yang akan diaudit..	27
4.2.	Perencanaan Audit TI	27
a.	Mengidentifikasi kemampuan teknis dan sumber daya yang dibutuhkan dalam proses audit.....	28
b.	Mengidentifikasi sumber informasi untuk di-review	28
c.	Menyiapkan rencana audit.....	28
d.	Menyusun Tim Audit dan pembagian tugasnya.....	29
e.	Menyiapkan <i>work documents</i> Audit TI.....	30
4.3.	Melaksanakan Prosedur Audit dan Pengumpulan Data.....	30
a.	Melakukan opening meeting.....	30
b.	Reviu dokumen dan pengumpulan data selama proses audit.....	30
c.	Komunikasi selama proses audit	30
d.	Menugaskan peran dan tanggung jawab untuk Tim Audit	31
e.	Mengumpulkan dan memverifikasi informasi.....	31
4.4.	Reviu dan Evaluasi Bukti.....	31
a.	Men- <i>generate</i> temuan audit.....	31
b.	Menyiapkan dokumentasi untuk laporan akhir.....	31
4.5.	Menyusun Kesimpulan dan Melaporkan Hasil Audit.....	32
a.	Menyusun Kesimpulan Audit TI.....	32
b.	Melaporkan Hasil Audit	33
c.	Mendistribusikan Laporan Audit.....	34
d.	Kegiatan Pasca Audit	35
4.6.	Rangkuman.....	36

4.7. Soal Latihan	37
BAB V KESIMPULAN.....	39
Kesimpulan.....	39
Tindak Lanjut.....	39
DAFTAR PUSTAKA	40
KUNCI JAWABAN SOAL LATIHAN	41

DAFTAR GAMBAR

Gambar 1. Prinsip COBIT (ISACA, 2012)	15
Gambar 2. Proses Manajemen IT pada COBIT 5	16
Gambar 3. Pemantauan dan Evaluasi SPBE.....	18
Gambar 4. Pemetaan Tata Cara Perencanaan Audit TI dengan Butir Juknis Prakom	19
Gambar 5. Pemetaan Tata Cara Pelaksanaan Audit TI dengan Butir Juknis Prakom	20
Gambar 6. Pemetaan Tata Cara Pelaporan Audit TI dengan Butir Juknis Prakom	21

BAB I PENDAHULUAN

1.1. Latar Belakang

Sejauh ini masih banyak organisasi yang mengalami kerugian dengan dampak langsung pada aset mereka yang paling berharga, yakni informasi. Penyerang selalu bisa mencari celah keamanan sistem dan mengeksploitasi kerentanannya. Serangan demi serangan yang terjadi bersama dengan pemberlakuan undang-undang dan peraturan terkini (terutama terkait dengan keamanan informasi) membuat Audit Teknologi Informasi (TI) menjadi bidang profesi yang kritis, dinamis, dan menantang yang akan terus berkembang di masa depan seiring dengan perkembangan bidang-bidang TI yang baru dan semakin menarik untuk dikuasai.

Modul Audit TI Jenjang Keahlian akan membantu peserta memahami seputar bidang profesi Audit TI, dengan berfokus tentang bagaimana Audit TI memberi manfaat kepada pejabat fungsional Pranata Komputer jenjang Keahlian dalam menilai validitas, keandalan, dan keamanan informasi secara efektif. Selain itu akan dijelaskan mengenai teknik, prosedur, dan kontrol yang dapat membantu peserta dalam menentukan efektivitas dan konsistensi dari aktivitas pengumpulan, pemrosesan, penyimpanan, dan pendistribusian informasi terhadap tujuan dan sasaran organisasi. Materi yang dijelaskan pada modul ini dikumpulkan dari beberapa sumber baik *textbook*, jurnal, *paper*, *training kit*, maupun sumber lainnya.

1.2. Deskripsi Singkat

Modul ini menguraikan kebutuhan bagi peserta untuk mengelola dan memeriksa sistem TI secara berkala dan efektif guna memenuhi tujuan dan sasaran bisnis. Di samping itu juga diberikan pengenalan mengenai prinsip, pengetahuan, dan keahlian tentang cara mengontrol dan menilai sistem TI yang dibutuhkan oleh seorang pejabat fungsional Pranata Komputer jenjang Keahlian dalam melakukan praktik Audit TI, mencakup: masalah-masalah

Audit TI, simulasi, kasus-kasus praktis, dan peluang penugasan penelitian untuk mengembangkan keahlian Audit TI.

1.3. Hasil Belajar

Setelah membaca Modul Audit TI diharapkan peserta mampu memahami:

1. Berbagai macam kerangka kerja Audit TI;
2. Alur proses dan evaluasi Audit TI serta penerapannya.

1.4. Indikator Hasil Belajar

Indikator-indikator hasil belajar meliputi:

1. Peserta mampu memilih suatu kerangka kerja sistematis (*best practice*) yang digunakan dalam Audit TI;
2. Peserta dapat menentukan ruang lingkup, kriteria dan tujuan Audit TI;
3. Peserta mampu melakukan perencanaan audit;
4. Peserta mampu melaksanakan prosedur audit dan pengumpulan data;
5. Peserta mampu melakukan reviu dan evaluasi bukti;
6. Peserta mampu menyusun kesimpulan dan opini hasil audit.

1.5. Materi Pokok

Modul ini terdiri dari lima bab. Pada bab pokok pembahasan, materi akan mencakup uraian materi, rangkuman, soal latihan, dan contoh kasus. Adapun pokok pembahasan dalam modul ini meliputi:

1. Pengenalan Audit TI,
2. Kerangka Kerja Audit TI,
3. Alur Proses Kegiatan Audit TI.

BAB II PENGENALAN AUDIT TI

2.1. Konsep dan Definisi Audit TI

Terdapat beberapa konsep dan definisi dari Audit Teknologi Informasi (Audit TI) berdasarkan berbagai sumber, antara lain:

- a. Kegiatan yang dilakukan secara sistematis dan objektif untuk menentukan dipatuhinya prosedur yang baku, instruksi, spesifikasi, kode, standar, administrasi atau program operasi yang dilakukan dalam bidang teknologi informasi (BPS, 2021).
- b. Proses yang sistematis untuk memperoleh dan mengevaluasi bukti secara objektif terhadap aset teknologi informasi dengan tujuan untuk menetapkan tingkat kesesuaian antara teknologi informasi dan komunikasi dengan kriteria dan/atau standar yang telah ditetapkan (BPPT, 2021).
- c. Audit TI adalah bentuk pengawasan dan pengendalian dari sumber daya teknologi informasi secara menyeluruh. Audit TI ini dapat berjalan bersama-sama dengan audit finansial dan audit internal, atau dengan kegiatan pengawasan dan evaluasi lain yang sejenis (ITGID, 2021).

2.2. Manfaat Audit TI

Audit TI memiliki berbagai manfaat yang dapat dilihat dari sudut pandang waktu pelaksanaan dan pihak yang terlibat di dalamnya. Audit TI dapat dilakukan pada saat setelah sebuah sistem atau aplikasi selesai dibangun dan baru akan diimplementasikan (*pre-implementation review*) dan dapat dilakukan pada saat setelah implementasi sistem dilakukan (*post-implementation review*). Manfaat audit TI pada masing-masing fase adalah sebagai berikut:

a. Manfaat Audit TI pada fase *Pre Implementation*:

- i. Mengetahui apakah sistem yang telah dibuat sesuai dengan kebutuhan ataupun memenuhi *acceptance criteria*
- ii. Mengetahui apakah pemakai/pengguna telah siap menggunakan sistem
- iii. Mengetahui apakah outcome sesuai dengan harapan institusi (*stakeholder*)

b. Manfaat Audit TI pada fase *Post Implementation*:

- i. Mendapat masukan atas risiko-risiko yang masih ada dan saran untuk penanganannya (terkait dengan manajemen risiko)
- ii. Sebagai bahan untuk perencanaan strategis dan rencana anggaran TI di masa mendatang (terkait *IT Enterprise*)
- iii. Sebagai *reasonable assurance* bahwa sistem informasi telah sesuai dengan kebijakan atau prosedur yang telah ditetapkan
- iv. Memastikan bahwa track pemeriksaan (audit) telah diaktifkan dan dapat digunakan oleh institusi (*stakeholder*)

Selain manfaat di atas, pelaksanaan Audit TI yang dilakukan oleh internal juga akan memberikan manfaat sebagai berikut:

- Menambah value organisasi dengan mengevaluasi efektivitas manajemen risiko di dua aspek sekaligus yakni organisasi dan TI
- Menawarkan assessment yang independen untuk melihat apakah sebuah project TI telah memenuhi tujuannya.
- Lebih dini mengidentifikasi key risk pada proyek TI

2.3. Tugas dan Peran Auditor TI

Orang yang melakukan proses audit disebut juga dengan Auditor. Auditor TI memiliki tugas untuk memastikan bahwa dalam merencanakan, melaksanakan, mengawasi, dan melaporkan penugasannya, telah dan hanya menggunakan pendekatan dan metode yang sesuai dengan peraturan

perundang-undangan, serta sesuai dengan kode etik dan standar profesi yang berlaku bagi Auditor TI.

Auditor TI juga harus menerapkan prinsip kehati-hatian dalam merencanakan, melaksanakan, mengawasi dan melaporkan penugasan auditnya, dengan memperhatikan hal-hal sebagai berikut :

- Lingkup pengujian audit yang diperlukan untuk menjamin pencapaian tujuan audit;
- Tingkat kompleksitas, materialitas dan signifikansi dari hal-hal yang diuji dalam audit;
- Kelayakan dan efektifitas manajemen resiko, pengendalian intern, dan tata kelola TI;
- Kemungkinan terdapatnya kesalahan, ketidakwajaran dan ketidakpatuhan yang signifikan;
- Keseimbangan sumber daya yang dibutuhkan untuk melakukan audit dengan manfaat keyakinan yang memadai yang akan diperoleh.

2.4. Rangkuman

- Audit TI adalah kegiatan evaluasi (pengawasan dan pengendalian) seluruh aset TI yang sistematis, objektif dan menyeluruh berdasarkan bukti-bukti tertentu.
- Audit TI dapat dilakukan pada fase pre-implementation dan fase-post implementation, masing-masing memiliki manfaat tersendiri
- Auditor adalah sebutan bagi orang yang melakukan Audit, dan memiliki peran untuk merencanakan, melaksanakan, mengawasi dan melaporkan penugasan audit yang diberikan kepadanya sesuai prinsip dan mekanisme yang berlaku.

2.5. Soal Latihan

1. Salah satu cakupan area dalam kegiatan audit TI yaitu ...
 - a. Keamanan gedung
 - b. Keamanan informasi
 - c. Keamanan personal
 - d. Keamanan lingkungan
2. Waktu yang tepat untuk melakukan audit TI yaitu ...
 - a. Kapan saja
 - b. Akhir tahun
 - c. Awal tahun
 - d. Sesuai rencana
3. Beberapa contoh kegiatan audit TI, kecuali ...
 - a. Memastikan anggaran selalu ada
 - b. Memastikan akses sistem selalu tersedia
 - c. Kondisi infrastruktur TI harus sesuai
 - d. Memastikan pengguna yang memiliki otorisasi
4. Salah satu manfaat Audit TI pada fase *Post Implementation* adalah ...
 - a. Mengetahui apakah pemakai/pengguna telah siap menggunakan sistem
 - b. Mengetahui apakah outcome sesuai dengan harapan institusi (*stakeholder*)
 - c. Mengetahui apakah sistem yang telah dibuat sesuai dengan kebutuhan ataupun memenuhi *acceptance criteria*
 - d. Sebagai bahan untuk perencanaan strategis dan rencana anggaran TI di masa mendatang

5. Dalam menggunakan pendekatan dan metode Audit TI, auditor perlu memperhatikan ...
 - a. manfaat Audit TI
 - b. kesesuaian dengan peraturan perundang-undangan, kode etik, dan standar profesi yang berlaku
 - c. bukti-bukti audit
 - d. fase pre-implementation dan post-implementation

BAB III KERANGKA KERJA AUDIT TI

Dalam Manajemen Teknologi Informasi atau Manajemen TI ada banyak standar TI atau *framework* TI yang digunakan secara internasional. Standar atau framework merupakan hasil kolaborasi pakar atau expert di bidangnya masing-masing dan merupakan ekstraksi dari *best practices* yang selama ini dimanfaatkan dalam bidang teknologi informasi.

Standar IT atau framework TI ini menjadi sangat penting untuk memastikan bahwa layanan TI bekerja sebagaimana mestinya sesuai dengan tujuan dan strategis bisnis, memiliki kualitas pelayanan yang efisien dan efektif, mengoptimalkan kualitas dan kuantitas layanan, memastikan budget yang dikeluarkan efektif, menjamin tingkat keamanan yang dapat dipertanggungjawabkan, dsb.

3.1. Standar dan Framework Audit TI

Secara umum standar dan framework digunakan untuk memastikan bahwa sumber daya TI (termasuk SDM-nya) dikelola untuk memberikan pelayanan yang optimal, efisien, efektif, dan aman. Standar atau framework yang paling banyak digunakan dalam pengembangan Manajemen Teknik Informasi antara lain :

COBIT

COBIT yang merupakan singkatan dari *Control Objectives for Information and Related Technology*, merupakan kerangka kerja yang dimiliki dan dikembangkan oleh ISACA (ISACA, 2012). COBIT Pertama kali diluncurkan pada tahun 1996. Versi yang terbaru saat ini adalah COBIT 2019, namun hingga saat ini COBIT 5 masih digunakan secara luas sebagai framework TI untuk Tata Kelola TI termasuk Audit TI. Di mana COBIT 5 merupakan gabungan dari framework COBIT 4.1, VAL IT 2.0, dan Risk IT.

COBIT dapat digunakan untuk membantu kita mengoptimalkan *value* atau nilai suatu organisasi enterprise melalui TI dengan cara menjaga keseimbangan antara realisasi keuntungan, optimalisasi risiko, dan pemanfaatan sumberdaya. Kerangka kerja TI ini meng-cover baik bisnis maupun unit TI dalam keseluruhan organisasi. COBIT juga memberikan model maturity atau model kematangan proses dan matriksnya untuk mengukur apakah organisasi TI telah mencapai tujuannya. COBIT juga menjaga keseimbangan antara kebutuhan stakeholder baik internal maupun eksternal.

ITIL

ITIL, singkatan dari *Information Technology Infrastructure Library*, merupakan seperangkat *guideline* (petunjuk) dan *best practices* untuk kebutuhan *IT Service Management* (ITSM) atau Manajemen Layanan Teknologi Informasi (MLTI). ITIL merupakan framework TI yang dikeluarkan oleh AXELOS Limited. ITIL fokus pada penyelarasan *IT services* atau layanan TI sesuai kebutuhan bisnis dan mendukung proses inti. ITIL Terdiri dari lima *volume* : *Service Strategy, Service Design, Service Transition, Service Operation and Continual Service Improvement*.

Kerangka kerja ITIL dapat diadopsi dan diaplikasikan kepada seluruh jenis bisnis dan lingkungan organisasi. ITIL mencakup petunjuk untuk identifikasi, perencanaan, delivering, dan supporting layanan TI. Jika sukses diadopsi, maka ITIL dapat meningkatkan kualitas layanan, menjadi alat mitigasi bagi risiko bisnis dan disrupsi layanan, meningkatkan hubungan dengan pelanggan, dan membuat suatu sistem efektif secara biaya bagi pengelolaan kebutuhan terhadap layanan.

CMMI

Framework CMMI merupakan singkatan dari *Capability Maturity Model Integration*, merupakan model yang sudah terkenal secara global sebagai model referensi yang dikembangkan melalui *best practices* yang memberikan

petunjuk untuk meningkatkan proses yang dapat memenuhi target bisnis dari suatu organisasi. Model ini dikembangkan oleh pakar di industri, pemerintahan, dan Software Engineering Institute (SEI).

CMMI meningkatkan proses bisnis suatu organisasi dengan menunjukkan keuntungan terukur dari tujuan bisnis dan visinya. Suatu organisasi dapat mengorganisasikan dan memprioritaskan metodologi, SDM, dan aktivitas bisnisnya melalui kerangka kerja yang diberikan oleh CMMI.

PMBOK

PMBOK adalah singkatan dari *Guide to the Project Management Body of Knowledge*, adalah suatu *guideline* yang secara internasional diakui untuk digunakan sebagai metode manajemen proyek dan merupakan produk dari PMI (Project Management Institute). PMBOK adalah standar yang secara luas diterima dan diakui sebagai basis untuk keseluruhan metode manajemen proyek.

PMBOK memberikan deskripsi yang mendalam mengenai isi dan pokok-pokok yang secara fundamental membahas mengenai manajemen proyek, namun fokusnya tidak pada implementasi teknis. Instruksi teknis justru lebih detail berada pada kerangka kerja PRINCE2. PMBOK sendiri terdiri dari 5 proses dasar : Initiating, Planning, Executing, Controlling and Monitoring, and Closing.

PRINCE2

PRINCE2 merupakan singkatan dari *Projects in a Controlled Environment*, merupakan *standar de facto* untuk metode manajemen proyek yang dimiliki oleh UK Cabinet Office. PRINCE2 adalah komplemen dari model PMBOK dengan menyediakan petunjuk yang berbasis proses dilengkapi dengan template yang siap digunakan oleh Manajer Proyek dan Group Project Steering pada setiap fase yang berbeda dari proyek. PRINCE2 memastikan kontrol yang lebih besar terhadap sumberdaya serta manajemen yang efektif terhadap risiko bisnis dan proyek.

Sebagai contoh, tujuh prinsip dari PRINCE2 menyatakan bahwa proyek harus dijalankan melalui siklus berikut : proyek harus memiliki justifikasi bisnis, definisi yang jelas untuk setiap peran dan tanggung jawab pada setiap fase dan proses, dikelola dalam bentuk tahapan yang detail dan terjadwal, definisi toleransi untuk setiap pengecualian dalam manajemen proyek, fokus pada menghasilkan produk sesuai dengan kebutuhan proyek, dan belajar dari pengalaman untuk peningkatan kualitas organisasi dalam mengelola proyek berikutnya.

ISO/IEC 20000

ISO/IEC 20000 adalah Service Management System (SMS) atau sistem manajemen layanan merupakan standarisasi internasional untuk manajemen layanan TI. Dimiliki oleh International Organization for Standardization (ISO) dan the International Electrotechnical Commission (IEC) dan secara umum selaras dengan ITIL.

ISO/IEC 20000 memiliki dua bagian. Bagian pertama mendefinisikan kebutuhan formal dari produksi berkualitas tinggi terhadap layanan kepada bisnis. TI yang meliputi kriteria perencanaan, manajemen layanan, dan produksi layanan dan juga manajemen pelanggan. Bagian kedua menjelaskan proses dari produksi layanan yang secara umum sama dengan proses ITIL yang secara umum memfokuskan pada proses manajemen pelanggan.

ISO 21500

ISO 21500 adalah standar yang secara generik merupakan petunjuk mengenai konsep dan proyek dari manajemen proyek yang merupakan bagian terpenting dalam realisasi proyek yang sukses. Dapat digunakan untuk seluruh jenis organisasi dan dapat diterapkan pada setiap jenis proyek, tanpa terkendala ukuran, kompleksitas, dan durasi.

ISO 21500 adalah standar informal secara umum lebih merupakan *guideline* ketimbang metodologi yang bersertifikasi. Menyediakan deskripsi high level terhadap konsep dan proses yang selama ini dianggap sebagai good

practices dalam manajemen proyek dan menempatkan proyek dalam konteks program dan portofolio proyek. PMBOK secara umum memiliki kesesuaian dengan ISO 21500 begitu juga sebaliknya.

ISO/IEC 38500

ISO/IEC 38500 merupakan standar yang memberikan prinsip umum mengenai peran dan manajemen IT governance dengan tanggung jawab bisnis (contoh : BoD dan tim manajemen). Dapat digunakan secara luas untuk semua jenis dan ukuran organisasi baik perusahaan privat maupun publik termasuk organisasi non profit.

Standar ini mendukung manajemen bisnis dalam melaksanakan supervisi terhadap organisasi TI dan membantunya memastikan bahwa TI memberikan dampak positif terhadap kinerja perusahaan. Standar ISO/IEC 38500 terdiri dari 6 prinsip sebagai berikut :

1. Responsibility
2. Strategy
3. Acquisition
4. Performance
5. Conformance
6. Human behaviour

ISO/IEC 38500 juga juga dapat dijadikan acuan untuk menjamin bahwa manajemen telah melaksanakan konformitas dengan implementasi tata kelola organisasi yang baik (good governance).

TOGAF

TOGAF adalah kerangka kerja *enterprise architecture* dari Open Group Standard yang memungkinkan setiap organisasi memiliki pendekatan terstruktur untuk mengelo implementasi teknologi, khususnya dalam desain pengembangannya, dan perawatan perangkat lunak. TOGAF Dipublikasikan tahun 1995 berdasarkan US Department of Defence Technical Architecture

Framework for Information Management (TAFIM), kemudian dikembangkan oleh The Open Group Architecture Forum dan secara reguler dirilis di website Open Group.

TOGAF meningkatkan efisiensi bisnis melalui metode yang konsisten, komunikasi, dan pemanfaatan sumberdaya yang efisien. Adopsi TOGAF dapat meningkatkan kredibilitas industri dengan bahasa yang umum di kalangan profesional enterprise architecture.

ISO/IEC 27001

ISO/IEC 27001 merupakan standarisasi isinya merupakan pedoman petunjuk dan prosedur praktis pengelolaan Sistem Manajemen Keamanan Informasi. ISO 27001 lebih memfokuskan diri pada aspek manajemen pelaksanaan, dimana keluaran dokumennya merinci hingga detail aktivitas keamanan yang perlu dilakukan. Proses implementasi maupun aktivitas audit keamanan sistem informasi bersifat fleksibel tergantung pada tipe dan kebutuhan organisasi serta fokus pada proses bisnis dan proses TI yang sesuai dengan tujuan strategis organisasi.

Selain ISO/IEC 27001, COBIT juga bisa digunakan untuk membangun Sistem Manajemen Keamanan Informasi khususnya bila kita menggunakan pedoman COBIT khusus untuk keamanan yaitu COBIT 5 for Information Risk. Bila kita ingin membangun Tata Kelola Keamanan Informasi yang meliputi Governance dan Management sekaligus maka COBIT adalah pilihan yang terbaik.

3.2. COBIT 5: Salah Satu Best Practice

COBIT dikembangkan oleh Institut Tata kelola TI (ITGI), yang merupakan bagian dari Information System Audit and Control Association (ISACA). COBIT pertama kali diperkenalkan pada tahun 1996, kemudian secara konsisten dikelola dan dikembangkan untuk menjadi bagian yang tak terpisahkan dari tata kelola TI dengan tujuan utama menetapkan serangkaian

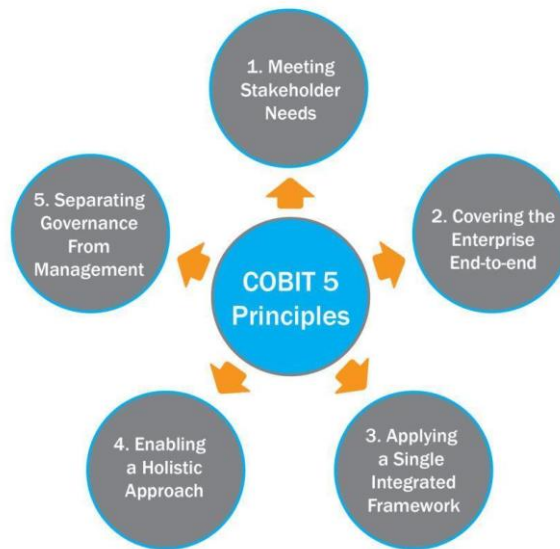
proses yang diperlukan untuk mengendalikan sumber daya TI dalam meraih tujuan bisnis organisasi.

COBIT terdiri dari seperangkat *control objectives* untuk bidang TI, dirancang untuk memudahkan tahapan-tahapan audit dan tata kelola TI organisasi. COBIT edisi pertama dirilis pada tahun 1996 dan kini sudah mencapai edisi ke-6 (COBIT 2019). Namun pada modul ini, pokok pembahasan akan mendiskusikan COBIT 5 (terbit tahun 2012) yang cakupannya tidak jauh dengan COBIT edisi terbaru.

COBIT 5 menyediakan prinsip-prinsip, praktik-praktik, alat-alat analisis, dan model yang diterima secara global dan dirancang untuk membantu memaksimalkan kepercayaan pimpinan bisnis dan TI mengenai nilai dari informasi dan aset teknologi perusahaan (ISACA, 2012). COBIT 5 memberikan perbedaan yang jelas antara fungsi pengelolaan (*governance*) dan manajemen TI pada organisasi.

COBIT 5 didasarkan pada lima prinsip kunci untuk tata kelola dan manajemen TI organisasi yaitu: memenuhi kebutuhan stakeholder, mencakup seluruh bagian organisasi, menerapkan suatu kerangka kerja yang terintegrasi, menggunakan sebuah pendekatan yang menyeluruh, dan pemisahan tata kelola dari manajemen.

Kelima prinsip dasar ini memungkinkan organisasi untuk membangun sebuah kerangka tata kelola dan manajemen yang efektif, sehingga dapat mengoptimalkan investasi dan penggunaan TI. Kelima prinsip digambarkan pada Gambar 1.



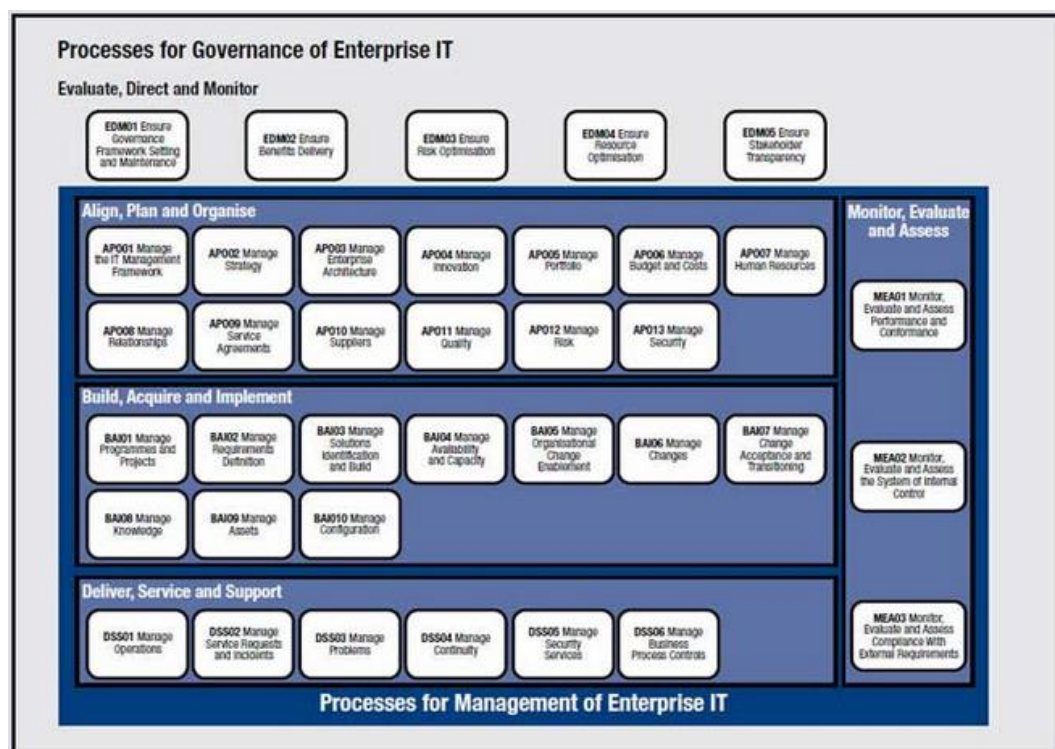
Gambar 1. Prinsip COBIT (ISACA, 2012)

Kerangka kerja COBIT, terdiri dari tiga tingkat (level) usaha pengaturan TI yang menyangkut manajemen sumber daya TI. Lapisan paling bawah, yaitu kegiatan dan tugas (activities and task) yang diperlukan untuk mencapai hasil yang dapat diukur. Pada aktivitas, terdapat konsep siklus hidup yang di dalamnya terdapat kebutuhan pengendalian khusus. Kemudian satu lapis di atasnya terdapat proses yang merupakan gabungan dari kegiatan dan tugas (activities and task) dengan keuntungan atau perubahan (pengendalian) alami. Pada tingkat yang lebih tinggi, proses biasanya dikelompokkan bersama ke dalam domain.

Pengelompokan ini sering disebut sebagai tanggung jawab domain dalam struktur organisasi dan yang sejalan dengan siklus manajemen atau siklus hidup yang dapat diterapkan pada proses TI. COBIT 5 membagi proses tata kelola dan manajemen TI perusahaan menjadi dua domain proses utama, proses tata kelola terdapat dalam domain Evaluate, Direct, dan Monitor (EDM), sedangkan proses- proses manajemen TI terdapat pada empat domain yaitu:

- Align, Plan, and Organize (APO)—Penyelarasan, Perencanaan, dan Pengaturan
- Build, Acquire, and Implement (BAI)—Membangun, Memperoleh, dan Mengimplementasikan
- Deliver, Service and, Support (DSS)—Mengirimkan, Layanan, dan Dukungan
- Monitor, Evaluate, and Assess (MEA)—Pengawasan, Evaluasi, dan Penilaian

Process Reference Model dalam COBIT 5 adalah pembaharuan dari model proses COBIT 4.1, dengan mengintegrasikan model proses dari Risk IT dan Val IT. Total terdapat 37 proses tata kelola dan manajemen dalam COBIT 5 yang dapat Dilihat pada Gambar 2.



Gambar 2. Proses Manajemen IT pada COBIT 5

Secara umum, setiap kegiatan Audit TI yang menggunakan kerangka kerja COBIT 5 akan mengevaluasi domain proses-proses diatas. Namun tidak

seluruh proses harus dicakup dalam satu kegiatan Audit TI, melainkan dapat dipilih sesuai dengan kebutuhan organisasi.

3.3. Standar dan Tata Cara Audit SPBE

Badan Pengkajian dan Penerapan Teknologi (BPPT) adalah lembaga pemerintah yang bertanggung jawab dalam penyelenggaraan SPBE secara nasional (Kemensetneg, 2018). Salah satu tugas yang berkaitan dengan tanggung jawab tersebut adalah menyusun standar dan tata cara pelaksanaan audit Sistem Pemerintahan Berbasis Elektronik atau disingkat SPBE (BPPT, 2021).

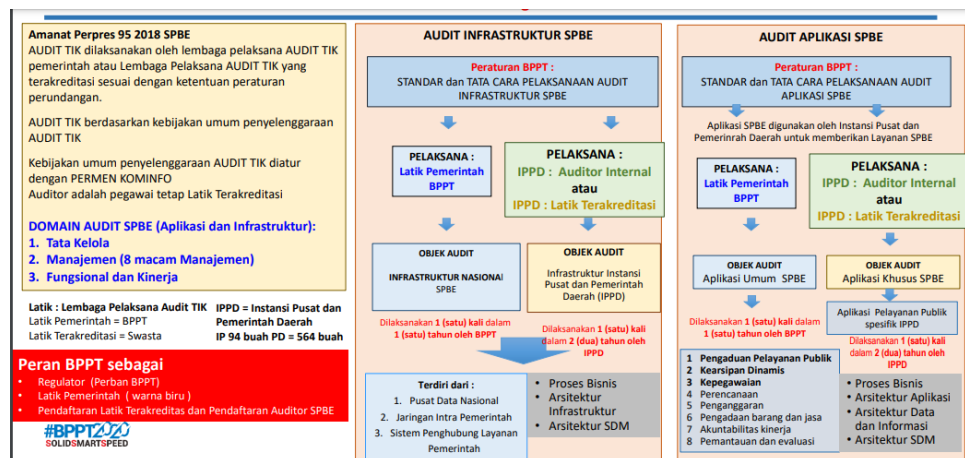
Peraturan tentang Audit TI sendiri telah tertuang pada Peraturan Presiden No. 95 Tahun 2018 tentang Sistem Pemerintahan Berbasis Elektronik Bab IV tentang Audit Teknologi Informasi dan Komunikasi Pasal 55, 56, 57 dan 58. Peraturan ini kemudian diturunkan pada Peraturan Menteri Komunikasi dan Informatika Republik Indonesia tentang Kebijakan Umum Penyelenggaraan Audit Teknologi Informasi dan Komunikasi Bab II tentang Pelaksanaan Audit Teknologi Informasi dan Komunikasi Pasal 4 sampai pasal 12. Pasal-pasal ini mencakup standar dan tata cara pelaksanaan Audit Infrastruktur SPBE dan Audit Aplikasi SPBE oleh BPPT, serta Audit Keamanan informasi oleh BSSN.

Standar dan tata cara pelaksanaan Audit Infrastruktur dan Audit Aplikasi digunakan sebagai panduan bagi IPPD (instansi pusat dan pemerintah daerah), Lembaga Audit TIK (LATIK) SPBE, dan Auditor dalam melaksanakan Audit Infrastruktur SPBE dan Audit Aplikasi SPBE. (Lebih kepada pelaksanaan Audit eksternal). Standar dan tata cara ini memuat panduan tata cara pelaksanaan audit, standar teknis dan kriteria penilaian audit, panduan LATIK sebagai pelaksana audit eksternal, dan panduan auditor.

Sebelum adanya Perpres SPBE ini, Audit TIK di IPPD tidak wajib dilaksanakan. Lembaga pelaksana audit, siapa auditornya, objek dan lingkup audit, standar teknis serta tata cara audit juga masih dibebaskan. Namun

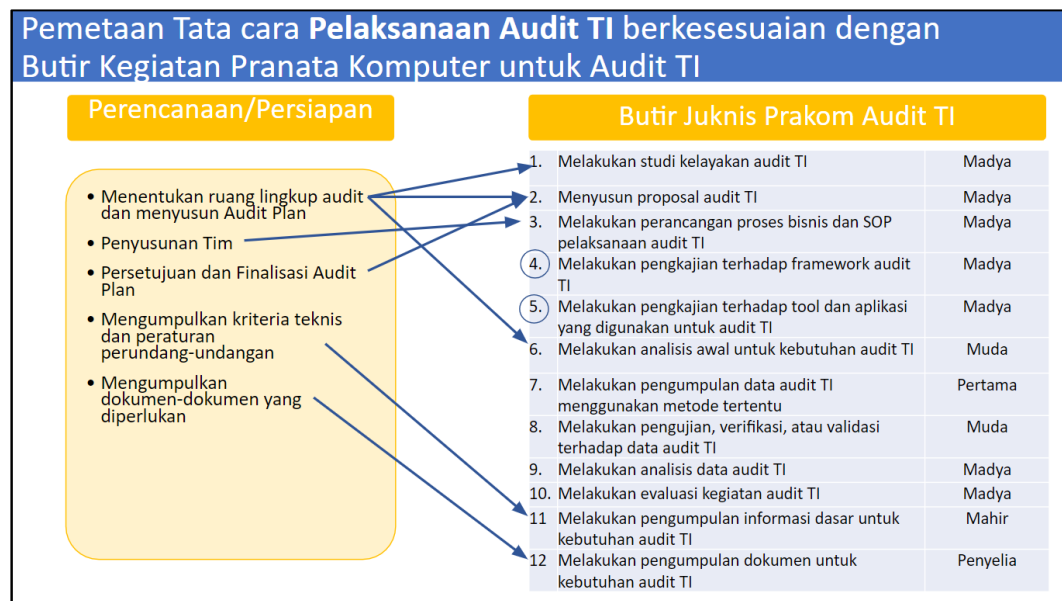
setelah adanya Perpres SPBE, Audit TI menjadi sebuah kegiatan yang harus dilaksanakan, dimana lembaga pelaksana audit dan auditornya telah diatur seperti yang sudah dilaksanakan oleh Lembaga Arsip Nasional Republik Indonesia (ANRI, 2021). Objek dan ruang lingkup Audit TI, ketentuan standar teknis dan tata cara audit TI juga kini telah ditentukan oleh BPPT dan BSSN.

Hal-hal yang dijelaskan di atas telah tercantum seluruhnya pada peraturan BKN yang kini masih berupa draft dan menunggu pengesahan RPM Kominfo. Meski demikian, kegiatan Audit TI yang dapat masuk dalam ketentuan sudah boleh dilaksanakan karena sudah sesuai Perpres SPBE.



Gambar 3. Pemantauan dan Evaluasi SPBE (Grahitandaru, 2021)

Adapun butir-butir kegiatan Audit TI pada Petunjuk Teknis (Juknis) Prakom telah mengadopsi standar dan tata cara pelaksanaan Audit TI SPBE mencakup 3 tahap utama yaitu tahap perencanaan, pelaksanaan dan pelaporan (Grahitandaru, 2021). Kesemuanya dipetakan dalam 12 (dua belas) butir kegiatan Audit TI yang tercantum dalam juknis. Gambar 4 menunjukkan butir kegiatan audit TI dari Juknis Prakom yang berkesesuaian dengan standar dan tata cara Audit SPBE.



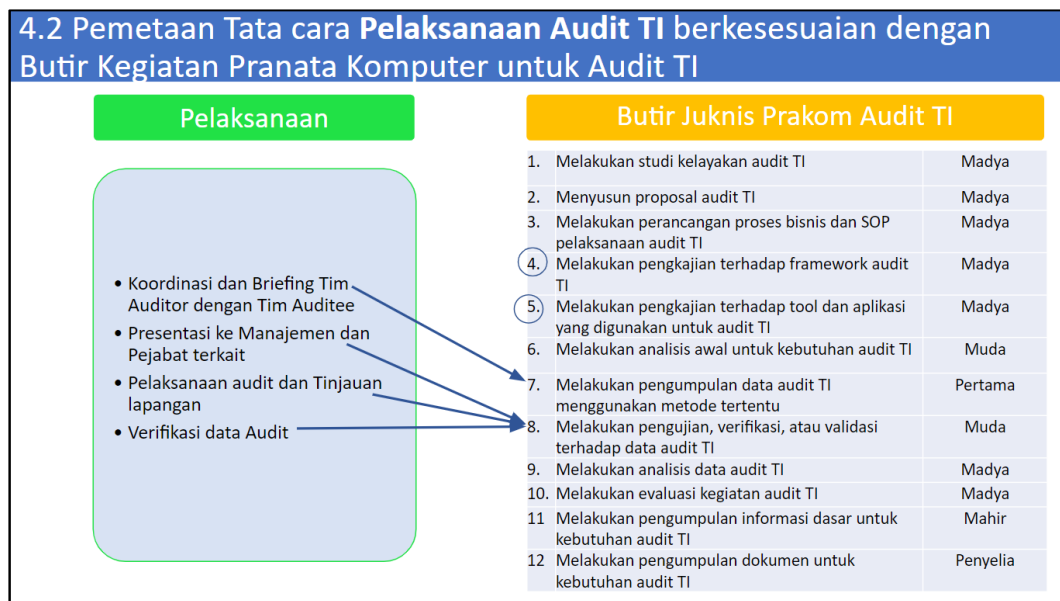
Gambar 4. Pemetaan Tata Cara Perencanaan Audit TI dengan Butir Juknis Prakom

Gambar 4 menunjukkan terdapat 6 (enam) butir kegiatan Audit TI pada Juknis Prakom yang berkesesuaian dengan tahap perencanaan pada Audit SPBE antara lain:

1. Melakukan studi kelayakan audit TI
2. Menyusun proposal Audit TI
3. Melakukan perancangan proses bisnis dan SOP pelaksanaan Audit TI
4. Melakukan analisis awal untuk kebutuhan Audit TI
5. Melakukan pengumpulan informasi dasar untuk kebutuhan Audit TI
6. Melakukan pengumpulan dokumen untuk kebutuhan Audit TI

Berikutnya, Gambar 5 menunjukkan terdapat 2 (dua) butir kegiatan Audit TI pada Juknis Prakom yang berkesesuaian dengan tahap pelaksanaan pada Audit SPBE antara lain:

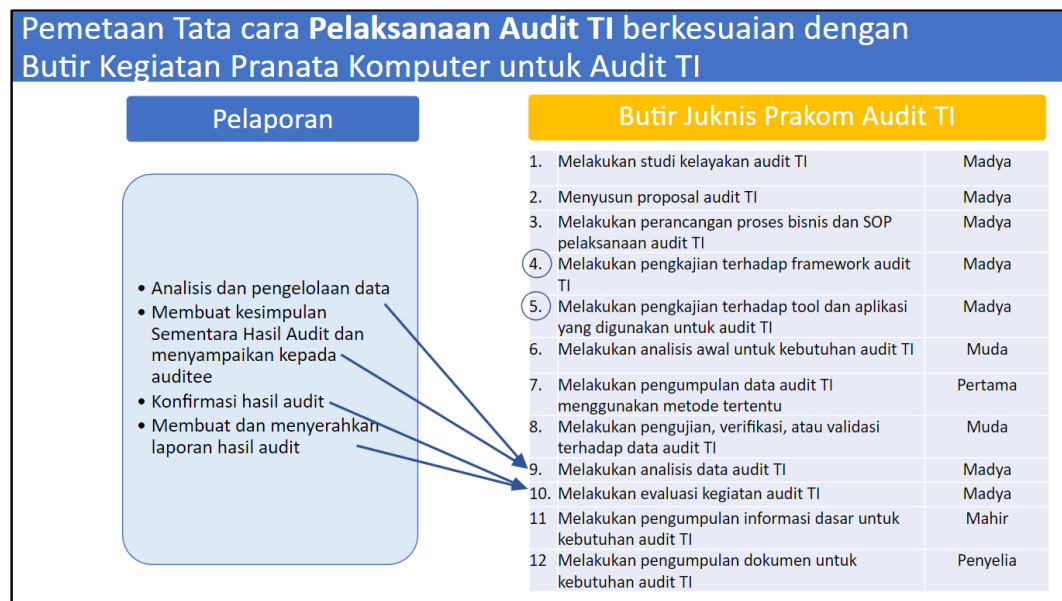
1. Melakukan pengumpulan data Audit TI menggunakan metode tertentu
2. Melakukan pengujian, verifikasi, atau validasi terhadap data Audit TI



Gambar 5. Pemetaan Tata Cara Pelaksanaan Audit TI dengan Butir Juknis Prakom

Selanjutnya, Gambar 6 menunjukkan terdapat 2 (dua) butir kegiatan Audit TI pada Juknis Prakom yang berkesesuaian dengan tahap perencanaan pada Audit SPBE antara lain:

1. Melakukan analisis data Audit TI
2. Melakukan evaluasi kegiatan Audit TI



Gambar 6. Pemetaan Tata Cara Pelaporan Audit TI dengan Butir Juknis Prakom

Terakhir, terdapat 2 (dua) butir kegiatan Audit TI dari Juknis Prakom yang bersifat independen untuk dilaksanakan di luar rangkaian sebuah kegiatan Audit yaitu:

1. Melakukan pengkajian terhadap framework audit TI
2. Melakukan pengkajian terhadap *tool* dan aplikasi yang digunakan untuk audit TI

Pada dasarnya, kedua kegiatan di atas dapat dilakukan kapan saja terlepas dari ada atau tidaknya kegiatan Audit TI yang sedang berjalan di organisasi. Namun demikian, tujuan kedua kegiatan di atas adalah untuk mencari, menelaah, mengkaji dan membuktikan kerangka kerja/framework serta tools dan aplikasi cocok atau tidak bagi sebuah kegiatan Audit. Terkait hal tersebut, maka kedua kegiatan paling ideal dilakukan sebelum dan atau setelah dilakukannya sebuah kegiatan Audit TI.

Kombinasi dari Jenis organisasi, ruang lingkup, objek, dan domain Audit TI bisa menyebabkan *framework* tertentu dapat cocok ataupun tidak

cocok (secara ilmiah) untuk digunakan dalam sebuah kegiatan Audit TI. Cakupan kegiatan kajian ini bersifat luas dan bisa jadi menghasilkan kerangka kerja kombinasi dari dua atau lebih kerangka kerja Audit TI yang telah dibahas sebelumnya.

3.4. Rangkuman

- Terdapat berbagai macam kerangka kerja Audit TI yang umum digunakan dan dijadikan acuan antara lain: COBIT, ITIL, CMMI, PMBOK, PRINCE2, dll
- COBIT 5 masih menjadi *framework* yang paling luas digunakan pada kegiatan Audit TI
- Terkait SPBE, telah tersusun standar dan tata cara pelaksanaan Audit Infrastruktur SPBE dan Audit Aplikasi SPBE oleh BPPT, serta Audit Keamanan informasi oleh BSSN.
- Seluruh butir kegiatan Audit TI pada Petunjuk Teknis (Juknis) Prakom telah mengadopsi standar dan tata cara pelaksanaan Audit TI SPBE mencakup 3 tahap yaitu: perencanaan, pelaksanaan dan pelaporan.

3.5. Soal Latihan

1. Berikut ini merupakan cakupan dari audit SPBE, kecuali ...
 - a. Aplikasi TI
 - b. Infrastruktur TI
 - c. Keamanan TI
 - d. Konsultan TI
2. Kegiatan audit TI sesuai dengan COBIT, kecuali ...
 - a. Build and develop
 - b. Plan and organize
 - c. Monitor and evaluate
 - d. Deliver and support
3. Framework Audit TI yang ditujukan untuk Enterprise Architecture, dan menyediakan pendekatan yang komprehensif terhadap desain, perencanaan, implementasi, dan tata kelola arsitektur informasi organisasi adalah ...
 - a. TOGAF
 - b. COBIT
 - c. ITIL
 - d. PMBOK
4. Dalam COBIT 5, domain untuk proses "Service Desk dan Manajemen Insiden" adalah ...
 - a. Deliver, Service and Support (DSS)
 - b. Monitor Evaluate and Assess (MEA)
 - c. Align, Plan and Organize (APO)
 - d. Build, Acquire and Implement (BAI)

5. Yang tidak termasuk ke dalam faktor penyebab cocok atau tidaknya suatu framework untuk digunakan dalam sebuah kegiatan Audit TI adalah ...
- a. jenis organisasi
 - b. *tool* dan aplikasi Audit TI
 - c. domain Audit TI
 - d. objek Audit TI

BAB IV ALUR PROSES KEGIATAN AUDIT TI

4.1. Menentukan Ruang Lingkup, Kriteria dan Tujuan Audit TI

Sebelum memulai proses audit TI, terlebih dulu diperlukan penentuan ruang lingkup, kriteria dan tujuan dari Audit TI yang akan dilaksanakan.

a. Mengidentifikasi kriteria Audit TI

Kriteria Audit TI merupakan berbagai peraturan perundang-perundangan dan/atau kebijakan, prosedur, dan instruksi kerja, serta standar dan praktik-praktik terbaik, yang digunakan oleh Auditor untuk melakukan evaluasi ataupun Audit TI. Umumnya, kriteria audit TI diambil dari variabel kontrol sistem informasi yang berkaitan dengan aktivitas:

1. Mengamankan aset
2. Memastikan siklus pengembang sistem atau aplikasi berjalan dengan baik dan beroperasi secara efektif
3. Memastikan Integritas environment OS terjaga
4. Memastikan Integritas environment aplikasi yang sensitif dan critical terjaga
5. Memastikan Kesesuaian identifikasi dan otentikasi pengguna
6. Memastikan Efisiensi dan efektivitas operasional
7. Memastikan Integritas dan reliabilitas sistem terjaga dengan mengimplementasi prosedur change management

b. Mengidentifikasi tujuan Audit TI yang relevan

Terdapat berbagai macam Tujuan Audit TI yang dapat ditetapkan, namun tidak semuanya akan relevan dengan sebuah organisasi. Untuk dapat menentukan tujuan atau objektif Audit TI yang tepat dan relevan sesuai dengan kondisi organisasi yang akan diaudit, maka Auditor perlu:

1. Memahami tujuan bisnis organisasi

Memahami tujuan bisnis organisasi secara garis besar dapat dilakukan dengan membaca laporan tahunan organisasi, renstra,

ataupun laporan independen dari pihak ketiga yang mengkaji proses bisnis organisasi. Selain kajian dokumen, dapat pula dilakukan wawancara terhadap *key person* yang tidak hanya memahami tujuan bisnis namun juga memahami kondisi TI organisasi. Auditor juga mencari dan mengkaji regulasi TI khusus yang berlaku di organisasi atau nasional, serta mengidentifikasi fungsi atau aktivitas TI organisasi yang diserahkan pada pihak ketiga sebagai bagian dari upaya untuk lebih memahami fokus organisasi.

2. Mereviu work paper dari kegiatan audit sebelumnya

Pada beberapa kasus, organisasi mungkin pernah melakukan kegiatan Audit pada periode sebelumnya baik dilakukan oleh pihak internal maupun dengan melibatkan pihak ketiga. Work paper atau kertas kerja audit TI yang lalu dapat dijadikan masukan untuk mempertimbangkan tujuan Audit TI yang relevan bagi organisasi.

3. Mengidentifikasi *stated content* yang dimiliki organisasi

Stated content adalah dokumen kebijakan, standard, guidelines, prosedur, dan struktur organisasi yang sudah dimiliki oleh organisasi. Hal ini juga bisa mencakup misalnya, Rencana Strategis TI organisasi.

4. Menentukan kelayakan Audit

Sebelum sebuah kegiatan Audit dapat dilakukan, perlu dilakukan pengujian kelayakan Audit TI melalui studi kelayakan Audit TI. Melakukan studi kelayakan audit TI adalah kegiatan meninjau dan menilai apakah audit TI layak untuk diselenggarakan di suatu institusi. Pelaku studi kelayakan mengidentifikasi area dan obyek TI dari institusi secara umum yang berpotensi untuk diaudit. Selain itu, dilakukan peninjauan kemungkinan pelaksanaan dari berbagai perspektif, baik teknis maupun non teknis dalam domain TI dan bisnis. Dengan demikian dapat diperoleh kesimpulan apakah kegiatan audit TI

untuk area dan obyek TI tersebut layak atau tidak layak untuk diimplementasikan di institusi.

Kegiatan studi kelayakan audit TI berlaku untuk per area TI dan wajib disertai dengan kegiatan melakukan analisis kelayakan audit TI dari berbagai perspektif di antaranya:

- Analisis kelayakan ekonomi, untuk mendapatkan justifikasi biaya-manfaat;
- Analisis kelayakan teknis, dengan meninjau penerapan teknis secara praktis dari kegiatan audit TI yang diusulkan;
- Analisis kelayakan operasional, dengan menguji seberapa efektif kegiatan audit TI yang diusulkan untuk diterapkan dan memberikan peluang kepada pelaksana;
- Analisis kelayakan hukum dan kontraktual (non teknis), dengan meninjau kewajiban-kewajiban hukum atau kontraktual yang berkaitan dengan kegiatan audit TI yang diusulkan; dan.
- Analisis kelayakan budaya organisasi, dengan mengevaluasi bagaimana internal instansi dapat menerima kegiatan audit TI untuk diterapkan.

c. Menentukan spesifikasi sistem dan unit/fungsi yang akan diaudit

Saat akan memasuki tahap perencanaan Audit TI maka perlu ditentukan spesifikasi cakupan sistem/aplikasi yang akan diaudit. Selain itu perlu ditentukan ruang lingkup unit/fungsi di organisasi yang akan diaudit.

Berdasarkan Juknis Prakom, Cakupan area TI meliputi namun tidak terbatas pada: keamanan informasi, manajemen layanan, manajemen konfigurasi, operasional sistem. Cakupan obyek TI: perangkat keras, piranti lunak, sarana komunikasi, serta fasilitas apapun yang dapat digunakan untuk menginput, menyimpan, mengirimkan, memproses, dan menghasilkan data dalam berbagai bentuk.

4.2. Perencanaan Audit TI

Auditor TI harus merencanakan Audit yang baik dengan terlebih dahulu mengidentifikasi sumber daya sistem informasi yang akan diaudit; tata kelola dan manajemen sistem informasi yang akan diaudit; dan Peraturan perundang-undangan yang terkait dengan sistem informasi yang akan diaudit. Aktivitas pada fase perencanaan Audit TI mencakup:

a. Mengidentifikasi kemampuan teknis dan sumber daya yang dibutuhkan dalam proses audit

Dalam fase perencanaan, kemampuan teknis dan sumber daya yang dibutuhkan dalam kegiatan Audit TI perlu diidentifikasi terlebih dahulu. Sumber daya audit yang dimaksud mencakup waktu, biaya dan sumber daya manusia (SDM). Auditor perlu mengidentifikasi berapa lama waktu yang diperlukan untuk menyelesaikan sebuah kegiatan audit (termasuk alokasi) dan kapan perkiraan rencana pelaksanaannya. Biaya yang diperlukan untuk kegiatan audit juga perlu diidentifikasi bersama jumlah anggota tim yang diperlukan dan memiliki kemampuan yang dibutuhkan. Sumber daya audit yang diidentifikasi dapat disesuaikan dengan objek, dan cakupan area TI yang sudah direncanakan.

b. Mengidentifikasi sumber informasi untuk di-review

Sumber informasi yang nantinya akan digunakan sepanjang proses Audit TI perlu diidentifikasikan pada fase perencanaan. Sumber informasi yang diidentifikasi bisa mencakup dokumen cetak, sumber dari internet atau informasi yang didapat melalui wawancara terhadap *key person* atau tenaga ahli yang terlibat langsung. Sumber. Sumber informasi ini akan menjadi sumber dari segala data, bukti dan referensi yang akan digunakan sepanjang kegiatan Audit TI

c. Menyiapkan rencana audit

Auditor Sistem Informasi harus menyusun Rencana Audit Sistem Informasi secara rinci dan jelas, yang mencakup :

1. Tujuan, lingkup, dan jenis Audit Sistem Informasi;

2. Tahapan dan prosedur pengujian Audit TI yang harus dilakukan;
3. Metodologi dan alat bantu Audit TI yang dapat digunakan oleh Auditor Sistem Informasi;
4. Jangka waktu pelaksanaan setiap tahapan dan prosedur pengujian dalam Audit TI;
5. Alokasi kepada Auditor TI yang harus melakukan prosedur pengujian tersebut.

d. Menyusun Tim Audit dan pembagian tugasnya

Tim Audit merupakan tim yang disusun khusus untuk pelaksanaan Audit TI dan biasanya tersusun secara berjenjang. Adapun posisi Tim Audit TI mencakup beberapa posisi antara lain:

1. Penanggungjawab, berperan melakukan monitoring dan evaluasi aktivitas audit untuk menjamin pelaksanaan audit sesuai dengan standar audit.
2. Lead Auditor, bertanggung jawab merencanakan audit teknologi, melaksanakan audit di lapangan, mengendalikan data dan melaporkan hasil audit teknologi. Lead Auditor harus mempunyai kualifikasi minimal setara dengan Auditor teknologi madya;
3. Auditor, bertugas membantu Lead Auditor dalam aktivitas audit teknologi. Auditor harus mempunyai kualifikasi minimal setara /dengan Auditor teknologi muda;
4. Asisten Auditor, bertugas membantu Auditor dalam aktivitas audit teknologi;
5. Teknisi, bertugas membantu Auditor dalam pengumpulan data lapangan;
6. Narasumber, berperan memberi masukan yang berkaitan dengan isu, status teknologi, dan keilmuan yang relevan.

Pada beberapa instansi Ketua Tim Audit (Lead Auditor) wajib memiliki sertifikat kompetensi Auditor. Sertifikasi kompetensi Auditor teknologi yang

berasal dari Lembaga Sertifikasi Profesi (LSP) bidang kompetensi Auditor teknologi atau LSP yang mendapat pengakuan dari BPPT.

e. Menyiapkan *work documents* Audit TI

Tim Auditor menyiapkan segala dokumen yang dibutuhkan untuk melaksanakan prosedur audit terutama untuk fase pengumpulan data. Dokumen-dokumen tersebut misalnya dokumen ceklis dari framework yang digunakan, kuesioner, daftar pertanyaan untuk wawancara, dan lain sebagainya.

4.3. Melaksanakan Prosedur Audit dan Pengumpulan Data

Prosedur Audit TI mencakup beberapa aktivitas antara lain:

a. Melakukan opening meeting

Pada tahap ini, Tim Auditor perlu menyampaikan rencana audit (audit plan) kepada Auditee (pihak yang diaudit) untuk dikaji dan diberi persetujuan, serta mengkomunikasikan dampak dari keterbatasan sumberdaya.

b. Reviu dokumen dan pengumpulan data selama proses audit

Dilakukan *review* atau penelaahan dokumen-dokumen yang diperlukan sebagai referensi maupun sebagai verifikasi bukti (*evidence*) dari terpenuhinya prosedur-prosedur. Selain itu, dalam rangka mengumpulkan informasi yang dibutuhkan maka dapat dilakukan pula observasi lapangan, pengujian di lapangan, dan wawancara.

c. Komunikasi selama proses audit

Selama dilakukannya kegiatan audit, Tim Auditor harus menjaga komunikasi yang konsisten antar anggota tim maupun dengan Auditee. Komunikasi ini juga mencakupi laporan yang memadai kepada pimpinan unit kerja yang diaudit mengenai tujuan, wewenang, tanggung jawab, dan *progress* audit.

d. Menugaskan peran dan tanggung jawab untuk Tim Audit

Tim Audit yang telah dibentuk sebelumnya bisa jadi terdiri dari beberapa orang dalam satu peran. *Lead Auditor* bertugas membagi tanggung jawab untuk setiap Auditor yang bekerja di bawahnya sesuai dengan cakupan kegiatan Audit yang sedang dikerjakan.

e. Mengumpulkan dan memverifikasi informasi

Seluruh *work documents* yang telah digunakan untuk menelaah dan mengumpulkan informasi sepanjang kegiatan Audit TI kemudian dikompilasi dan diverifikasi.

4.4. Reviu dan Evaluasi Bukti

Setelah proses pengumpulan data di lapangan selesai, maka dilakukan penelaahan dan evaluasi dari bukti-bukti yang telah diperiksa, Evaluasi bukti dapat dilakukan melalui berbagai metode seperti kuesioner, wawancara/FGD, review dokumen dan observasi. Bukti dievaluasi berdasarkan kriteria audit yang telah ditentukan sebelumnya. Dua aktivitas utama pada tahap ini adalah:

a. Men-generate temuan audit

Berdasarkan hasil reviu dan evaluasi bukti selesai dilakukan maka temuan audit harus dihasilkan. Temuan Audit TI harus mencakup masalah-masalah penting atau isu yang ditemukan selama audit berlangsung, dan masalah tersebut pantas untuk dikemukakan dan dikomunikasikan dengan Auditee karena mempunyai dampak terhadap perbaikan dan peningkatan kinerja-ekonomi, efisiensi, dan efektifitas pada pihak Auditee.

b. Menyiapkan dokumentasi untuk laporan akhir

Auditor harus mendokumentasikan seluruh informasi yang terkait dengan pelaksanaan prosedur audit dan berbagai bukti yang diperolehnya di dalam seperangkat Kertas Kerja (*work paper*) Audit Sistem Informasi, yang harus memenuhi ketentuan sebagai berikut:

1. Disusun menggunakan Bahasa Indonesia, dengan lengkap, jelas, terstruktur, dan memiliki indeks, agar mudah untuk dipahami dan digunakan oleh Audit Sistem Informasi atau pihak lain yang akan melakukan review atas Kertas Kerja Audit tersebut.
2. Memungkinkan dilakukannya pelaksanaan ulang seluruh kegiatan yang telah dilaksanakan selama penugasan Audit Sistem Informasi tersebut oleh pihak independen dan memperoleh hasil dan kesimpulan yang sama.
3. Mencantumkan identitas pihak yang melaksanakan setiap tahapan dan pengujian Audit Sistem Informasi serta peranannya, serta telah diperiksa oleh pihak lain di dalam Tim Audit Sistem Informasi.

4.5. Menyusun Kesimpulan dan Melaporkan Hasil Audit

Setelah temuan Audit sudah dihasilkan dan dokumentasi untuk laporan akhir telah disiapkan, maka selanjutnya perlu dilakukan penyusunan kesimpulan audit, pelaporan hasil audit, dan pelaksanaan kegiatan pasca audit TI (jika telah ditentukan pada saat perencanaan Audit TI)

a. Menyusun Kesimpulan Audit TI

Auditor Sistem Informasi, harus menyampaikan Temuan dan Rekomendasi Audit Sistem Informasi jika ditemukan adanya kelemahan atau kekurangan atas rancangan dan/atau pelaksanaan pengendalian intern, manajemen risiko, dan kelola TI, dimana Temuan dan Rekomendasi Audit Sistem Informasi paling sedikit mencakup informasi sebagai berikut:

1. Temuan, yaitu berbagai fakta mengenai kelemahan atau kekurangan rancangan dan pelaksanaan atas rancangan dan/atau pelaksanaan pengendalian intern TI, manajemen risiko TI, dan tata kelola TI yang ditemukan oleh Auditor Sistem Informasi yang didasarkan kepada bukti-bukti audit yang diperoleh dari hasil pelaksanaan prosedur pengujian Audit Sistem Informasi. Termasuk hasil review dan evaluasi kelengkapan dokumen, kebijakan dan prosedur;

2. Risiko, yaitu dampak yang disebabkan oleh adanya kondisi tersebut diatas, yang secara aktual telah terjadi atau memiliki potensi untuk terjadi, yang telah atau akan dapat mempengaruhi pencapaian sebagian atau keseluruhan tujuan dari pengendalian intern TI, manajemen risiko TI dan tata kelola TI;
3. Kriteria, yaitu berbagai peraturan perundang-perundangan dan/atau kebijakan, prosedur, dan instruksi kerja, serta standar dan praktik-praktik terbaik, yang digunakan oleh Auditor Sistem Informasi untuk melakukan evaluasi dan pengujian atas pengendalian intern TI, manajemen risiko TI dan tata kelola TI;
4. Rekomendasi, yaitu berbagai tindakan perbaikan yang menurut Auditor Sistem Informasi dapat atau harus dilakukan oleh pihak yang terkait, untuk menghilangkan dan/atau mengendalikan berbagai hal yang menjadi penyebab, serta menghilangkan dan/atau mengendalikan berbagai dampak, dari adanya berbagai kelemahan atau kekurangan atas rancangan dan/atau pelaksanaan pengendalian intern TI, dan manajemen risiko TI serta tata kelola TI yang terkait, termasuk di dalamnya:
 - Rekomendasi prosedur tindak lanjut hasil audit
 - Rekomendasi prosedur untuk mengevaluasi efisiensi dan efektivitas;
5. Tanggapan, yaitu klarifikasi atau penjelasan dan argumentasi atau tanggapan resmi dari pihak-pihak yang terkait dan/atau bertanggung jawab atas hal-hal yang terkait dengan temuan dan rekomendasi yang disampaikan oleh Auditor Sistem Informasi.

b. Melaporkan Hasil Audit

Setelah menyelesaikan kegiatan Audit TI, Tim Auditor wajib memberi laporan yang memadai kepada pimpinan unit kerja yang diaudit dan pimpinan LATIK SPBE mengenai hasil dan kinerja audit yang dilaksanakan dalam

sebuah pertemuan atau *closing meeting*. Pada pertemuan ini laporan hasil penugasan audit yang telah disusun akan disampaikan.

Laporan Hasil Audit TI disusun dalam Bahasa Indonesia dan minimal mencakup informasi sebagai berikut:

- Identitas organisasi, pihak-pihak yang berhak menerima, dan pembatasan distribusi atau sirkulasi laporan tersebut;
- Tujuan, aspek dan periode yang dicakup, serta sifat, waktu, dan kedalaman audit;
- Hasil Audit berupa temuan, kesimpulan, dan rekomendasi Audit Sistem Informasi, serta, jika ada, pengecualian dan pembatasan terkait dengan lingkup audit;
- Tanggapan dan/atau komentar resmi atas Laporan Hasil Audit Sistem Informasi dari pihak-pihak yang bertanggungjawab atas entitas atau kegiatan yang diaudit
- Tanggal pelaporan, serta nama, jabatan dan tanda tangan Ketua Tim Audit Sistem Informasi;
- Ringkasan Eksekutif, yang merupakan ringkasan dari Laporan Hasil Audit Sistem Informasi, khususnya mengenai hal-hal yang menurut Auditor Sistem Informasi cukup material dan signifikan dan perlu mendapatkan perhatian dari pihak-pihak yang bertanggung jawab atas entitas atau kegiatan yang diaudit.

c. Mendistribusikan Laporan Audit

Laporan Audit TI yang telah disampaikan pada closing meeting umumnya perlu didistribusikan kepada pihak-pihak berwenang yang dianggap perlu dan memiliki peran dalam perbaikan dari temuan-temuan hasil Audit tersebut. Tujuan distribusi laporan Audit dapat ditentukan oleh pihak yang memberikan penugasan maupun pihak yang bertanggungjawab dari sisi Auditee.

d. Kegiatan Pasca Audit

Tindak lanjut hasil audit dapat dilakukan jika memang sudah ditentukan dan dicantumkan pada rencana audit (*Audit Plan*). Tim Auditor TI dalam memantau tindak lanjut Audit dapat mencakup :

1. Mencatat jangka waktu yang harus dipenuhi oleh satuan kerja yang bertanggung jawab untuk menindaklanjuti temuan dan rekomendasi Audit Sistem Informasi;
2. Jika dipandang perlu, dapat melakukan penugasan khusus atau tambahan dalam rangka melakukan evaluasi dan verifikasi atas tindak lanjut yang telah dilaporkan;
3. Apabila terdapat tindak lanjut yang belum dilaksanakan atau yang dipandang kurang memadai pelaksanaannya, Auditor Sistem Informasi harus menyampaikan atau mengeskalasikan hasil pemantauan tindak lanjut Audit Sistem Informasi tersebut kepada satuan kerja yang terkait atau kepada pejabat yang lebih tinggi.

Auditor TI dalam melakukan evaluasi dan verifikasi kelayakan tindak lanjut atas temuan dan rekomendasi Audit Sistem Informasi, harus memperhatikan faktor sebagai berikut :

1. Signifikansi dari temuan dan rekomendasi Audit Sistem Informasi tersebut;
2. Adanya perubahan terhadap lingkungan Sistem Informasi yang dapat mempengaruhi signifikansi permasalahan atau risiko yang terkait dengan temuan dan rekomendasi tersebut;
3. Sumber daya dan kompleksitas serta jangka waktu yang dibutuhkan untuk melaksanakan tindak lanjut dari temuan dan rekomendasi Audit Sistem Informasi tersebut;
4. Dampak yang mungkin ditimbulkan jika tindak lanjut dari temuan dan rekomendasi tersebut tidak atau gagal dilakukan;

4.6. Rangkuman

- a. **Menentukan Ruang Lingkup, Kriteria dan Tujuan Audit TI:** Sebelum menyusun rencana Audit TI perlu dilakukan penentuan ruang lingkup, kriteria dan tujuan audit TI yang relevan dan sesuai dengan tujuan strategis TI organisasi dan tujuan bisnis organisasi secara keseluruhan
- b. **Perencanaan Audit TI:** Perencanaan audit harus disusun dalam sebuah Rencana Audit (*Audit Plan*) yang rinci dan mengidentifikasi sumber daya Audit, sumber informasi yang akan ditelaah, penetapan Tim Audit, dan persiapan *work document* yang akan digunakan pada pelaksanaan Audit,
- c. **Melaksanakan Prosedur Audit dan Pengumpulan Data:** Prosedur pelaksanaan Audit dimulai dengan *opening meeting*, dan dilanjutkan dengan pengumpulan dan penelaahan dokumen dan atau bukti di lapangan. Pada tahap ini, komunikasi yang konsisten dan pembagian peran internal Tim Audit harus jelas. Data dan bukti perlu diverifikasi sebelum masuk dalam tahap selanjutnya.
- d. **Reviu dan Evaluasi Bukti:** Berdasarkan hasil fase pelaksanaan, maka temuan Audit TI harus dihasilkan dan seluruh informasi mengenai temuan tersebut harus didokumentasikan sebagai bahan dasar dari laporan Audit TI yang akan disusun.
- e. **Menyusun Kesimpulan dan Melaporkan Hasil Audit:** Berdasarkan hasil temuan Audit pada fase sebelumnya, Tim Auditor perlu menyusun kesimpulan audit, melaporkan hasil audit (termasuk mendistribusikan laporan), dan melaksanakan kegiatan pasca audit TI jika telah ditentukan sejak saat perencanaan Audit TI.

4.7. Soal Latihan

1. Yang perlu disampaikan dalam *opening meeting* adalah ...
 - a. Laporan Hasil Audit TI
 - b. Temuan dan Rekomendasi
 - c. Evaluasi bukti
 - d. Dampak dari keterbatasan sumberdaya
2. Berikut ini adalah informasi yang tercakup dalam kesimpulan Audit TI, kecuali ...
 - a. Temuan
 - b. Rekomendasi
 - c. Kriteria
 - d. Tujuan Pelaporan
3. Aktivitas yang tidak termasuk ke dalam proses Menentukan ruang lingkup, kriteria dan tujuan Audit TI yaitu ...
 - a. Mengidentifikasi kriteria Audit TI
 - b. Mengidentifikasi kemampuan teknis dan sumber daya yang dibutuhkan dalam proses audit
 - c. Menentukan spesifikasi sistem dan unit/fungsi yang akan diaudit
 - d. Mengidentifikasi tujuan Audit TI yang relevan
4. Tim Auditor berkewajiban memberi laporan mengenai hasil dan kinerja audit yang dilaksanakan dalam sebuah ...
 - a. wawancara
 - b. FGD
 - c. *closing meeting*
 - d. kuesioner

5. Posisi dalam Tim Audit TI yang bertugas membantu Auditor dalam pengumpulan data lapangan adalah ...
- a. Asisten Auditor
 - b. Narasumber
 - c. Penanggungjawab
 - d. Teknisi

BAB V KESIMPULAN

Kesimpulan

Audit Teknologi Informasi merupakan kegiatan yang dilakukan secara sistematis dan objektif untuk menentukan dipatuhinya prosedur yang baku, instruksi, spesifikasi, kode, standar, administrasi atau program operasi yang dilakukan dalam bidang teknologi informasi.

Auditor adalah pihak yang diberi tugas menjalankan proses audit terhadap pihak Auditee (pihak yang diaudit). Auditor TI memiliki tugas untuk memastikan bahwa dalam merencanakan, melaksanakan, mengawasi, dan melaporkan penugasannya, telah dan hanya menggunakan pendekatan dan metode yang sesuai dengan peraturan perundang-undangan, serta sesuai dengan kode etik dan standar profesi yang berlaku bagi Auditor TI.

Terdapat berbagai kerangka kerja (*framework*) *best practices* yang sudah secara luas digunakan oleh berbagai organisasi, Pemilihan *framework* idealnya disesuaikan dengan kebutuhan dan kondisi organisasi. Alur dan proses Audit TI yang disampaikan pada modul ini merupakan ketentuan umum dan dapat secara spesifik ditentukan detailnya pada masing-masing organisasi.

Tindak Lanjut

Dengan berbekal modul ini peserta diharapkan dapat mengenal konsep, kerangka kerja dan alur proses kegiatan Audit TI secara umum. Peserta juga diharapkan memiliki pengetahuan awal jika instansinya ingin mengkaji kerangka kerja dan melaksanakan kegiatan Audit TI internal.

DAFTAR PUSTAKA

- ANRI (Arsip Nasional Republik Indonesia). 2021. "Peraturan Arsip Nasional Republik Indonesia Nomor 11 Tahun 2021 tentang Standar dan Tata Cara Pelaksanaan Audit Teknologi Informasi dan Komunikasi Sistem Pemerintahan Berbasis Elektronik di Lingkungan Arsip Nasional Republik Indonesia."
- BPPT (Badan Pengkajian dan Penerapan Teknologi). 2021. "Draft Peraturan Badan Pengkajian dan Penerapan Teknologi Republik Indonesia Tahun 2021 tentang Standar dan Tata Cara Pelaksanaan Audit Infrastruktur dan Audit Aplikasi Sistem Pemerintahan Berbasis Elektronik."
- BPS (Badan Pusat Statistik). 2021. "Peraturan Badan Pusat Statistik Nomor 2 Tahun 2021 tentang Petunjuk Teknis Penilaian Angka Kredit Jabatan Fungsional Pranata Komputer."
- Grahitandaru, Andrari. 2021. "Urgensi Audit SPBE."
- ISACA (Information Systems Audit and Control Association). 2012. *COBIT 5: A Business Framework for the Governance and Management of Enterprise IT*. ISACA.
- ITGID (IT Governance Indonesia). 2021. "IT Audit." Diambil 27 Februari 2022 (<https://itgid.org/it-audit/>).
- Kemensetneg (Kementerian Sekretariat Negara RI). 2018. "Peraturan Presiden Republik Indonesia Nomor 95 Tahun 2018 tentang Sistem Pemerintahan Berbasis Elektronik."

KUNCI JAWABAN SOAL LATIHAN

Bab II

1. b.
2. d.
3. a.
4. d.
5. b.

Bab III

1. d.
2. a.
3. a.
4. a.
5. b.

Bab IV

1. d.
2. d.
3. b.
4. c.
5. d.